Informe de Incidente de Ciberseguridad

Ataque de inundación SYN (SYN flood) — Denegación de servicio (DoS)

Contexto del escenario

Como analista de seguridad en una agencia de viajes, recibí una alerta automática del sistema de monitoreo indicando un problema con el servidor web. Al intentar acceder al sitio de ventas de la empresa, el navegador devolvía un error de tiempo de espera de conexión agotado.

Mediante un analizador de paquetes (Wireshark) capturé el tráfico hacia y desde el servidor web, observando un volumen anormalmente alto de peticiones TCP SYN provenientes de una única dirección IP desconocida. El objetivo de este análisis fue identificar el tipo de ataque, explicar cómo afectaba al servidor y proponer medidas de mitigación.

Evidencia: registro de tráfico (Wireshark)

Registro TCP con código de colores: verde = conexiones legítimas; rojo = actividad del ataque (203.0.113.0); amarillo = conexiones legítimas fallando por el ataque.

Color Coded TCP Log

Color Key:

green	Normal TCP connection handshakes
red	Attack activity
yellow	Normal TCP connections failing due to attack

Color as te	No.	& milliseconds)	Source	Destination	Protocol
green	47	3.144521	198.51.100.23	192.0.2.1	TCP
green	48	3,195755	192.0.2.1	198.51.100.23	TCP
green	49	3,246989	198.51.100.23	192.0.2.1	TCP
green	50	3,298223	198.51.100.23	192.0.2.1	HTTP
green	51	3,349457	192.0.2.1	198.51.100.23	HTTP
red	52	3,390692	203.0.113.0	192.0.2.1	TCP
red	53	3,441926	192.0.2.1	203.0.113.0	TCP
red	54	3,49316	203.0.113.0	192.0.2.1	TCP
green	55	3,544394	198.51.100.14	192.0.2.1	TCP
green	56	3,599628	192.0.2.1	198.51.100.14	TCP
red	57	3,664863	203.0.113.0	192.0.2.1	TCP
green	58	3,730097	198.51.100.14	192.0.2.1	TCP
red	59	3,795332	203.0.113.0	192.0.2.1	TCP
green	60	3,860567	198.51.100.14	192.0.2.1	HTTP
red	61	3,939499	203.0.113.0	192.0.2.1	TCP
green	62	4,018431	192.0.2.1	198.51.100.14	HTTP
green	63	4,097363	198.51.100.5	192.0.2.1	TCP
red	64	4,176295	192.0.2.1	203.0.113.0	TCP
green	65	4,255227	192.0.2.1	198.51.100.5	TCP
red	66	4,256159	203.0.113.0	192.0.2.1	TCP
green	67	5,235091	198.51.100.5	192.0.2.1	TCP
red	68	5,236023	203.0.113.0	192.0.2.1	TCP
green	69	5,236955	198.51.100.16	192.0.2.1	TCP
red	70	5,237887	203.0.113.0	192.0.2.1	TCP
green	71	6,228728	198.51.100.5	192.0.2.1	HTTP
red	72	6,229638	203.0.113.0	192.0.2.1	TCP
yellow	73	6,230548	192.0.2.1	198.51.100.16	TCP
red	74	6,330539	203.0.113.0	192.0.2.1	TCP
green	75	6,330885	198.51.100.7	192.0.2.1	TCP
red	76	6,331231	203.0.113.0	192.0.2.1	TCP
yellow	77	7,330577	192.0.2.1	198.51.100.5	TCP
red	78	7,351323	203.0.113.0	192.0.2.1	TCP
green	79	7,360768	198.51.100.22	192.0.2.1	TCP
yellow	80	7,380773	192.0.2.1	198.51.100.7	TCP
red	81	7,380878	203.0.113.0	192.0.2.1	TCP

red 82	7,383879	203.0.113.0	192.0.2.1	TCP
red 83	7,482754	192.0.2.1	203.0.113.0	TCP
red 84	7,581629	203.0.113.0	192.0.2.1	TCP
yellow 85	7,680504	192.0.2.1	198.51.100.22	TCP
red 86	7,709377	203.0.113.0	192.0.2.1	TCP
red 87	7,738241	203.0.113.0	192.0.2.1	TCP
red 88	7,767105	203.0.113.0	192.0.2.1	TCP
red 89	13,895969	192.0.2.1	203.0.113.0	TCP
red 90	13,919832	203.0.113.0	192.0.2.1	TCP
red 91	13,943695	203.0.113.0	192.0.2.1	TCP
yellow 92	13,967558	192.0.2.1	198.51.100.16	TCP
red 93	13,991421	203.0.113.0	192.0.2.1	TCP
red 94	14,015245	203.0.113.0	192.0.2.1	TCP
red 95	14,439072	192.0.2.1	203.0.113.0	TCP
red 96	14,862899	203.0.113.0	192.0.2.1	TCP
green 97	14,886727	198.51.100.9	192.0.2.1	TCP
red 98	15,310554	203.0.113.0	192.0.2.1	TCP
red 99	15,734381	203.0.113.0	192.0.2.1	TCP
red 100	16,158208	192.0.2.1	203.0.113.0	TCP
red 101	16,582035	203.0.113.0	192.0.2.1	TCP
red 102	17,005862	203.0.113.0	192.0.2.1	TCP
red 103	17,429678	192.0.2.1	203.0.113.0	TCP
red 104	17,452693	203.0.113.0	192.0.2.1	TCP
red 105	17,475708	203.0.113.0	192.0.2.1	TCP
red 106	17,498723	203.0.113.0	192.0.2.1	TCP
red 107	17,521738	203.0.113.0	192.0.2.1	TCP
red 108	17,544753	203.0.113.0	192.0.2.1	TCP
red 109	17,567768	192.0.2.1	203.0.113.0	TCP
red 110	17,590783	203.0.113.0	192.0.2.1	TCP
red 111	18,413795	203.0.113.0	192.0.2.1	TCP
red 112	18,436807	203.0.113.0	192.0.2.1	TCP
red 113	18,459819	203.0.113.0	192.0.2.1	TCP
red 114	18,482831	203.0.113.0	192.0.2.1	TCP
red 115	18,506655	203.0.113.0	192.0.2.1	TCP
red 116	18,529667	203.0.113.0	192.0.2.1	TCP
red 117	18,552679	192.0.2.1	203.0.113.0	TCP
red 118	18,875692	203.0.113.0	192.0.2.1	TCP
red 119	19,198705	203.0.113.0	192.0.2.1	TCP
red 120	19,521718	203.0.113.0	192.0.2.1	TCP
yellow 121	19,844731	192.0.2.1	198.51.100.9	TCP
red 122	20,167744	203.0.113.0	192.0.2.1	TCP
red 123	20,490757	203.0.113.0	192.0.2.1	TCP
red 124	20,81377	192.0.2.1	203.0.113.0	TCP
red 125	21,136783	203.0.113.0	192.0.2.1	TCP
red 126	21,459796	203.0.113.0	192.0.2.1	TCP
red 127	21,782809	203.0.113.0	192.0.2.1	TCP
red 128	22,105822	203.0.113.0	192.0.2.1	TCP
red 129	22,428835	203.0.113.0	192.0.2.1	TCP
red 130	22,751848	203.0.113.0	192.0.2.1	TCP
red 131	23,074861	203.0.113.0	192.0.2.1	TCP
red 132	23,397874	203.0.113.0	192.0.2.1	TCP
red 133	23,720887	203.0.113.0	192.0.2.1	TCP
red 134	24,0439	203.0.113.0	192.0.2.1	TCP
red 135	24,366913	203.0.113.0	192.0.2.1	TCP

192.0.2.1: servidor web · 198.51.100.0/24: equipos de empleados (tráfico legítimo) · 203.0.113.0: IP atacante.

Sección 1: Identificación del ataque

El error de tiempo de espera de conexión se explica por un ataque de denegación de servicio (DoS) del tipo inundación SYN (SYN flood). Los registros muestran que una única IP desconocida (203.0.113.0) envía un volumen anormalmente alto de paquetes TCP SYN al servidor (192.0.2.1) en el puerto 443, sin completar el protocolo de enlace de tres vías. A medida que avanza el ataque, el servidor comienza a rechazar o reiniciar (RST) conexiones de usuarios legítimos. Como el tráfico proviene de una sola IP, corresponde a un DoS y no a un DDoS (que usaría múltiples fuentes distribuidas).

Sección 2: Cómo el ataque provoca el mal funcionamiento

Protocolo de enlace TCP de tres vías (three-way handshake):

1. SYN: el cliente envía un paquete SYN al servidor para solicitar una conexión.
2. SYN-ACK: el servidor responde con SYN-ACK, reservando recursos y confirmando la solicitud.
3. ACK: el cliente responde con ACK y la conexión queda establecida; recién entonces se transmiten datos.

Efecto del ataque: el servidor responde con SYN-ACK a cada petición y reserva recursos esperando el ACK final. Como el atacante nunca completa el handshake, esas conexiones quedan “medio abiertas” ocupando la tabla de conexiones. Al recibir miles de SYN falsos, el servidor agota su memoria y capacidad, y deja de aceptar conexiones nuevas. Las conexiones de empleados legítimos (198.51.100.x) empiezan a fallar o son reiniciadas (RST), lo que explica el error de tiempo de espera y deja el sitio de ventas inaccesible.

Impacto y mitigación

Consecuencias: indisponibilidad del sitio web, empleados sin acceso a la página de ventas, pérdida de oportunidades comerciales y daño a la reputación de la empresa.

Medidas recomendadas: limitación de tasa (rate limiting) en el firewall; cookies SYN para no reservar recursos hasta completar el handshake; sistemas de detección/prevención de intrusiones (IDS/IPS); y servicios de protección anti-DDoS.

Ejercicio 2 — Curso 3 (Seguridad de redes), Certificado Profesional de Ciberseguridad de Google. Trabajo propio basado en un escenario ficticio del curso. — Felipe Urtubia